

Fundamentos de Modelagem de Ameaças

Threat Modeling

DLH Academy · Segurança de Aplicações Web

1. Introdução

O que é Modelagem de Ameaças?

A modelagem de ameaças é uma abordagem estruturada para identificar, quantificar e tratar riscos de segurança em um sistema. É uma prática de segurança proativa que ajuda as organizações a compreender as potenciais ameaças antes que se materializem em ataques reais.

Pense na modelagem de ameaças como uma revisão do projeto de segurança. Assim como arquitetos revisam plantas de construção em busca de pontos fracos estruturais, os profissionais de segurança utilizam a modelagem de ameaças para identificar fraquezas de segurança no design dos sistemas.

Por que a Modelagem de Ameaças é Importante

Insight Principal: Encontrar e corrigir problemas de segurança durante o design é 100x mais barato do que corrigi-los em produção.

A modelagem de ameaças é essencial porque:

- Detecção Precoce: Identifica vulnerabilidades antes que o código seja escrito
- Eficiência de Custos: Corrigir falhas de design é muito mais barato do que patches pós-implantação
- Visão Abrangente: Fornece uma compreensão holística da segurança do sistema
- Priorização de Riscos: Ajuda a alocar recursos de segurança de forma eficaz
- Conformidade: Atende a requisitos regulatórios (PCI-DSS, HIPAA, GDPR)
- Cultura de Segurança: Constrói consciência de segurança nas equipes de desenvolvimento

Relevância no Mundo Real

A modelagem de ameaças é utilizada em diversos setores:

- Serviços Financeiros: Proteção de dados financeiros e transações de clientes
- Saúde: Segurança de registros de pacientes e dispositivos médicos
- E-commerce: Proteção de informações de pagamento e contas de usuários
- IoT: Proteção de dispositivos conectados contra ataques remotos
- Serviços em Nuvem: Segurança de ambientes multilocatários e APIs
- Governo: Proteção de infraestrutura crítica e informações classificadas

Objetivos de Aprendizagem

Ao final deste guia, você será capaz de:

- Explicar os conceitos fundamentais de segurança, incluindo a Tríade CIA
- Diferenciar entre ativos, ameaças, vulnerabilidades e riscos
- Aplicar a metodologia STRIDE para identificar ameaças
- Utilizar o sistema DREAD para priorizar riscos
- Seguir um processo estruturado de modelagem de ameaças em 6 etapas

2. Conceitos Fundamentais de Segurança

A Tríade CIA

A Tríade CIA é a base da segurança da informação, representando três princípios fundamentais:



Figura 1 – A Tríade CIA: Confidencialidade, Integridade e Disponibilidade

Confidencialidade

Definição:

Garantir que as informações sejam acessíveis apenas para quem tem autorização.

Ameaças:

- Acesso não autorizado a dados
- Ataques Man-in-the-Middle
- Violações de dados (Data Breaches)
- Engenharia social

Controles:

- Criptografia (em repouso e em trânsito)
- Listas de controle de acesso (ACLs)
- Autenticação multifator (MFA)
- Políticas de classificação de dados

Exemplo:

Um aplicativo de saúde deve garantir que os registros médicos dos pacientes sejam visualizados apenas por profissionais de saúde autorizados, e não por outros pacientes ou terceiros não autorizados.

Integridade

Definição:

Garantir que as informações sejam precisas, completas e não tenham sido adulteradas.

Ameaças:

- Adulteração de dados
- Injeção de SQL
- Ataques Man-in-the-Middle
- Modificações não autorizadas

Controles:

- Assinaturas digitais
- Funções hash (SHA-256)
- Controle de versão
- Validação de entrada
- Restrições de banco de dados

Exemplo:

Um aplicativo bancário deve garantir que os valores das transações não possam ser modificados durante a transmissão ou armazenamento.

Disponibilidade

Definição:

Garantir que as informações e recursos estejam acessíveis aos usuários autorizados quando necessário.

Ameaças:

- Ataques de Negação de Serviço (DoS)
- Ataques Distribuídos de Negação de Serviço (DDoS)
- Falhas de hardware
- Desastres naturais
- Ransomware

Controles:

- Balanceamento de carga
- Sistemas de redundância e failover
- Serviços de proteção contra DDoS
- Backups regulares
- Planos de recuperação de desastres

Exemplo:

Um site de e-commerce deve permanecer acessível para os clientes 24 horas por dia, 7 dias por semana, especialmente durante os períodos de pico de compras.

Ativos, Ameaças, Vulnerabilidades e Riscos

Compreender esses quatro conceitos é fundamental para uma modelagem de ameaças eficaz:

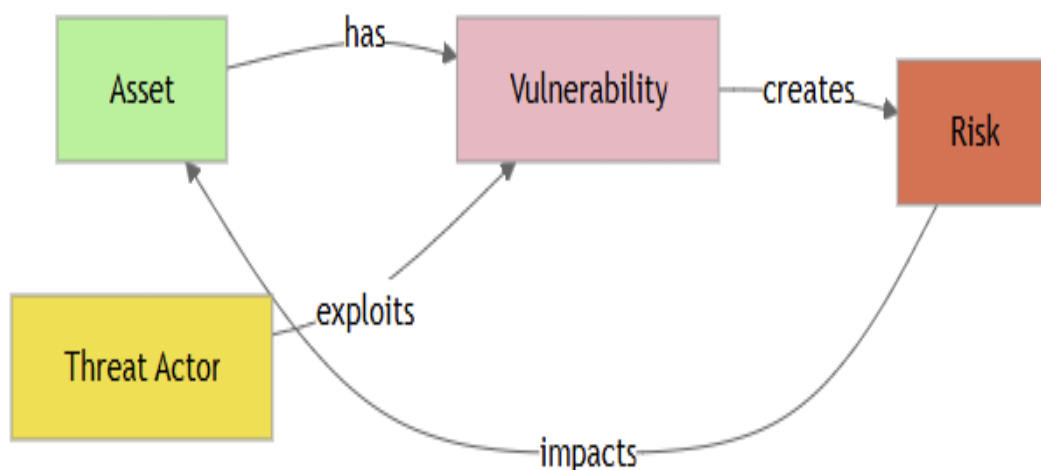


Figura 2 – Relação entre Ativos, Ameaças, Vulnerabilidades e Riscos

Ativos

Definição:

Qualquer coisa de valor para a organização que precisa de proteção.

Tipos de Ativos:

- Dados: Informações de clientes, registros financeiros, propriedade intelectual
- Hardware: Servidores, estações de trabalho, dispositivos móveis, sensores IoT
- Software: Aplicações, bancos de dados, sistemas operacionais
- Serviços: APIs, serviços em nuvem, sistemas de autenticação
- Pessoas: Funcionários, contratados, administradores
- Reputação: Imagem da marca, confiança dos clientes

Exemplos de Ativos:

Tipo de Ativo	Exemplo	Criticidade
Dados	Números de cartão de crédito de clientes	Crítico
Dados	Endereços de e-mail de usuários	Alto
Hardware	Servidor de banco de dados em produção	Crítico
Software	API de processamento de pagamentos	Crítico
Reputação	Marca da empresa	Alto

Ameaças

Definição:

Causas potenciais de incidentes indesejados que podem prejudicar um sistema ou organização.

Tipos de Ameaças:

- Natural: Inundações, incêndios, terremotos
- Humanas (Intencionais): Hackers, insiders maliciosos, concorrentes
- Humanas (Não Intencionais): Exclusão acidental, configuração incorreta
- Técnicas: Falhas de hardware, bugs de software, interrupções de rede

Agentes de Ameaça:

- Script kiddies (baixa habilidade)
- Hacktivistas (motivação política)
- Cibercriminosos (motivação financeira)
- Estados-nação (altamente sofisticados)
- Insiders maliciosos (acesso privilegiado)

Vulnerabilidades

Definição:

Fraquezas em um sistema que podem ser exploradas por ameaças.

Vulnerabilidades Comuns:

- Software sem patches de segurança
- Senhas fracas
- Criptografia ausente
- APIs inseguras
- Falhas de injeção SQL
- Cross-site scripting (XSS)
- Armazenamento em nuvem mal configurado
- Registro e monitoramento insuficientes

Exemplo de Vulnerabilidade:

```
# VULNERABLE CODE - SQL Injection
def login(username, password):
    query = f"SELECT * FROM users WHERE username='{username}' AND password='{password}'"
    # Attacker can input: ' OR '1'='1
    return execute_query(query)
# SECURE CODE - Parameterized Query
def login(username, password):
    query = "SELECT * FROM users WHERE username=? AND password=?"
    return execute_query(query, (username, hash_password(password)))
```

Figura 3 – Exemplo de Vulnerabilidade

Riscos

Definição:

A probabilidade e o impacto de uma ameaça explorar uma vulnerabilidade.

Fórmula de Risco:

$$\text{Risco} = \text{Probabilidade} \times \text{Impacto}$$

Níveis de Risco:

Probabilidade	Impacto	Nível de Risco
Alta	Alta	Crítico
Alta	Média	Alto
Média	Alta	Alto
Média	Média	Médio
Baixa	Alta	Médio
Baixa	Média	Baixo
Baixa	Baixa	Baixo

Superfícies de Ataque e Vetores de Ataque

Superfície de Ataque

Definição:

A soma de todos os pontos possíveis onde um atacante pode entrar ou extrair dados de um sistema.

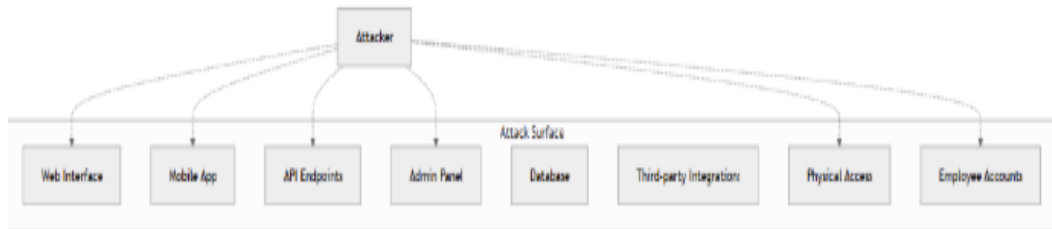


Figura 4 – Componentes da Superfície de Ataque

Componentes da Superfície de Ataque:

- Rede: Portas abertas, serviços de rede, APIs
- Aplicação: Entradas de usuário, uploads de arquivos, mecanismos de autenticação
- Humano: Alvos de engenharia social, usuários privilegiados
- Físico: Acesso ao prédio, dispositivos de hardware

Reduzindo a Superfície de Ataque:

- Desabilitar serviços e portas desnecessários
- Implementar o princípio do mínimo privilégio
- Remover funcionalidades e código não utilizados
- Segmentar redes
- Usar firewalls e controles de acesso

Vetor de Ataque

Definição:

O caminho ou método específico usado por um atacante para explorar uma vulnerabilidade.

Vetores de Ataque Comuns:

- Phishing: E-mails enganosos para roubar credenciais
- Injeção de SQL: Consultas maliciosas ao banco de dados
- Cross-Site Scripting (XSS): Injeção de scripts maliciosos
- Malware: Vírus, trojans, ransomware
- Man-in-the-Middle: Interceptação de comunicações
- Força Bruta: Adivinhação sistemática de senhas
- Exploits de Zero-Day: Exploração de vulnerabilidades desconhecidas
- Engenharia Social: Manipulação de pessoas para divulgar informações

Exemplo de Vetor de Ataque:

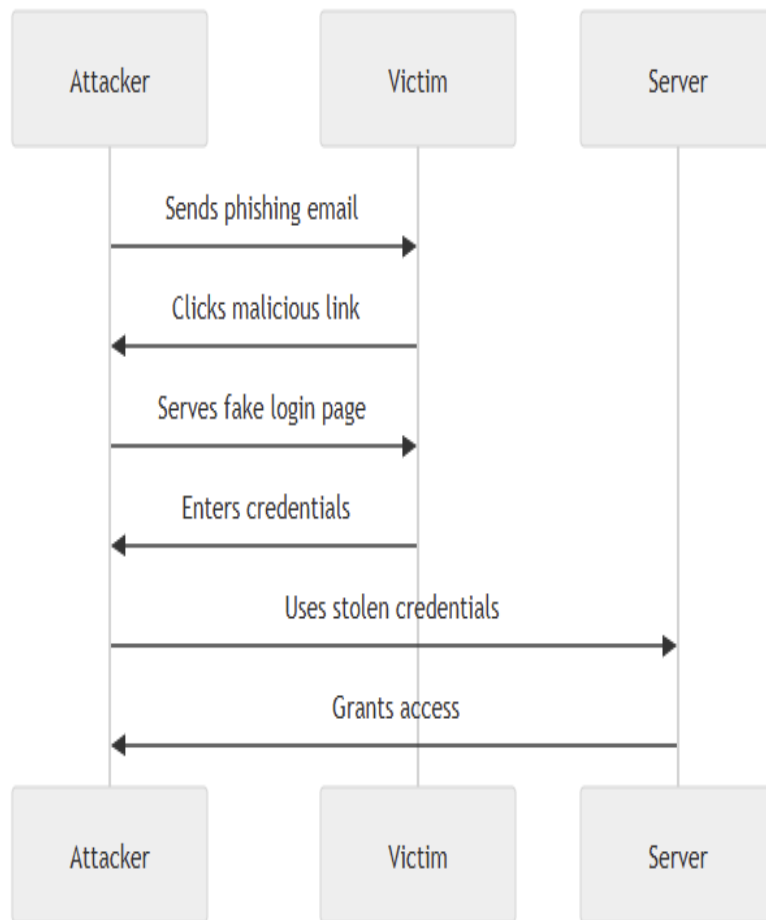


Figura 5 – Exemplo de Vetor de Ataque

Fronteiras de Confiança (Trust Boundaries)

Definição:

Linhas traçadas nos diagramas do sistema que separam diferentes zonas de confiança onde dados ou controle mudam de nível de confiança.

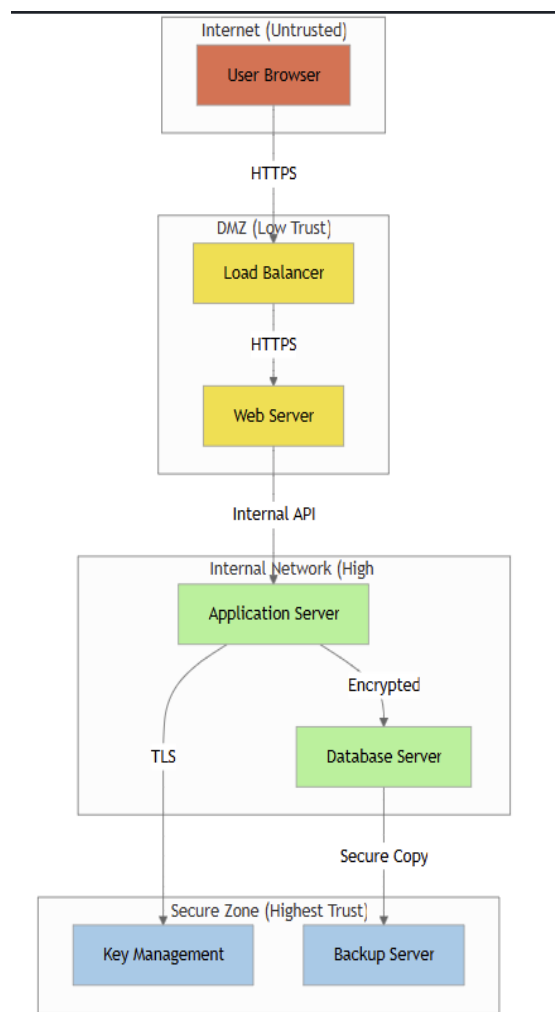


Figura 6 – Diagrama de Fronteiras de Confiança

Por que as Fronteiras de Confiança são Importantes:

- Dados que cruzam fronteiras requerem validação e sanitização
- Verificações de autenticação/autorização devem ocorrer nas fronteiras
- A criptografia é frequentemente necessária ao cruzar fronteiras
- Registro e monitoramento devem rastrear cruzamentos de fronteiras

Exemplos de Fronteiras de Confiança:

- Navegador do usuário → Servidor web (Internet → DMZ)
- Servidor web → Servidor de aplicação (DMZ → Interno)
- Aplicação → Banco de dados (Camada de aplicação → Camada de dados)
- Rede interna → Serviço em nuvem (Local → Nuvem)
- Contexto de usuário → Contexto de admin (Fronteira de escalação de privilégios)

Conclusão Principal: Toda vez que dados ou controle cruzam uma fronteira de confiança, representa um potencial risco de segurança que deve ser tratado com controles adequados.

3. Metodologias de Modelagem de Ameaças

Metodologia STRIDE

STRIDE é um framework de modelagem de ameaças desenvolvido pela Microsoft que categoriza ameaças em seis tipos. É uma das metodologias mais amplamente utilizadas na indústria.

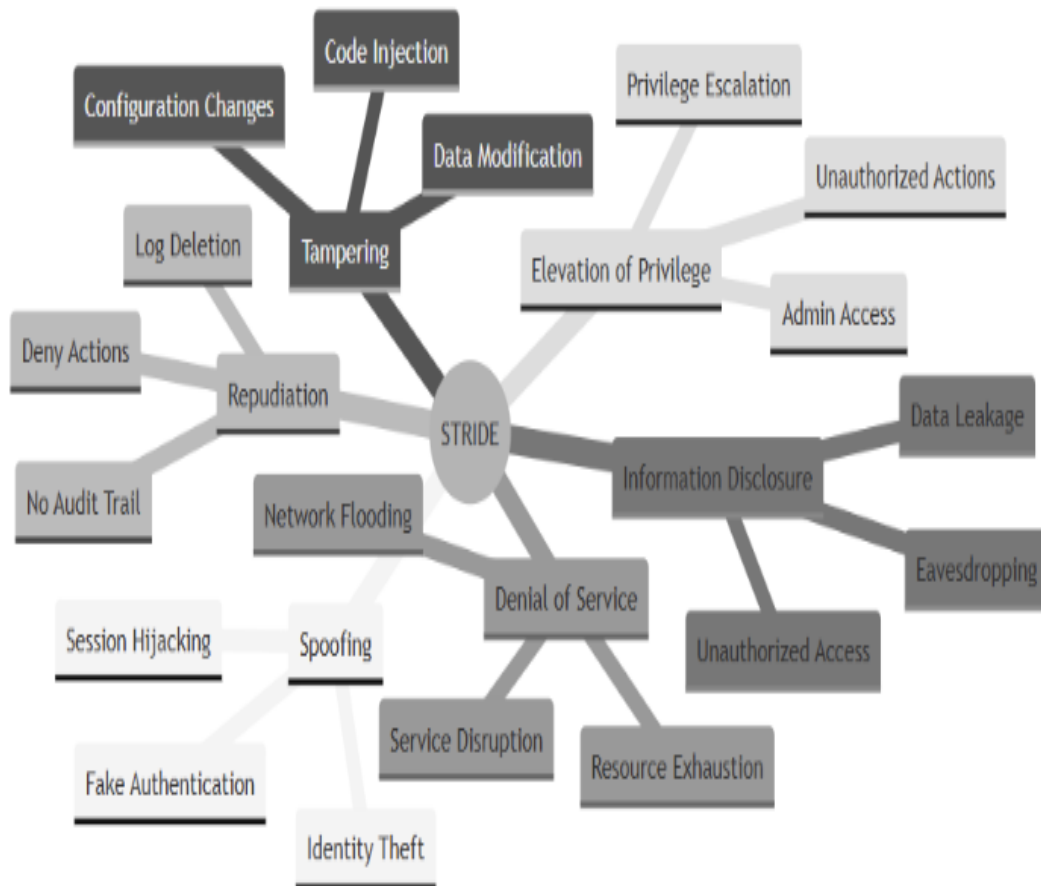


Figura 7 – As seis categorias do STRIDE

S – Falsificação de Identidade (Spoofing)

Definição:

Fingir ser algo ou alguém que você não é.

Exemplos:

- Personificar outro usuário roubando credenciais
- Falsificar endereços de remetente de e-mail
- Falsificação de endereço IP
- Roubo de token de sessão
- Certificados SSL falsos

Estratégias de Mitigação:

- Implementar autenticação forte (MFA)
- Usar assinaturas digitais
- Implementar gerenciamento adequado de sessão
- Usar autenticação TLS mútua

- Implementar medidas anti-falsificação (SPF, DKIM para e-mail)

Exemplo do Mundo Real:

Um atacante rouba o cookie de sessão de um usuário e o usa para se passar pelo usuário em um site de e-commerce, fazendo pedidos sem autorização.

T – Adulteração de Dados (Tampering)

Definição:

Modificar dados ou código de forma maliciosa.

Exemplos:

- Alterar dados em trânsito (man-in-the-middle)
- Modificar registros do banco de dados
- Alterar arquivos de configuração
- Ataques de injeção SQL
- Modificar binários da aplicação

Estratégias de Mitigação:

- Usar criptografia (TLS/SSL)
- Implementar assinaturas digitais
- Usar funções hash para verificações de integridade
- Validação e sanitização de entrada
- Implementar registro de auditoria
- Usar restrições e triggers de banco de dados

Exemplo do Mundo Real:

Um atacante intercepta uma transação bancária online e altera o número da conta destinatária antes de ela chegar ao servidor do banco.

R – Repúdio (Repudiation)

Definição:

Negar que você realizou uma ação sem qualquer forma de provar o contrário.

Exemplos:

- Usuário nega ter feito uma compra
- Excluir ou adulterar arquivos de log
- Afirmar "Nunca recebi esse e-mail"
- Negar ações administrativas

Estratégias de Mitigação:

- Implementar registro e auditoria abrangentes
- Usar assinaturas digitais para não-repúdio
- Implementar carimbo de tempo seguro
- Armazenar logs em locais à prova de adulteração
- Usar blockchain para trilhas de auditoria críticas
- Implementar agregação e backup de logs

Exemplo do Mundo Real:

Um funcionário exclui arquivos importantes e afirma nunca ter tido acesso a eles, mas não há logs para provar o que aconteceu.

I – Divulgação de Informações (Information Disclosure)

Definição:

Expor informações a pessoas não autorizadas.

Exemplos:

- Expor conteúdo do banco de dados
- Vazar dados sensíveis em mensagens de erro
- Ataques de travessia de diretório
- Endpoints de API não protegidos
- Arquivos de configuração expostos
- Dumps de memória contendo dados sensíveis

Estratégias de Mitigação:

- Criptografar dados sensíveis (em repouso e em trânsito)
- Implementar controles de acesso adequados
- Sanitizar mensagens de erro
- Usar práticas de codificação segura
- Implementar classificação de dados
- Auditorias de segurança regulares e testes de penetração

Exemplo do Mundo Real:

Uma aplicação web exibe mensagens de erro detalhadas que revelam informações do esquema do banco de dados, ajudando atacantes a criar ataques de injeção SQL.

D – Negação de Serviço (Denial of Service)

Definição:

Tornar um sistema ou aplicação indisponível para usuários legítimos.

Exemplos:

- Ataques DDoS inundando a rede com tráfego
- Ataques de esgotamento de recursos
- Ataques na camada de aplicação (Slowloris)
- Ransomware bloqueando sistemas
- Esgotamento do pool de conexões do banco de dados

Estratégias de Mitigação:

- Implementar limitação de taxa (rate limiting)
- Usar serviços de proteção contra DDoS (Cloudflare, AWS Shield)
- Implementar gerenciamento adequado de recursos
- Usar escalonamento automático (auto-scaling)
- Implementar circuit breakers
- Configurar monitoramento e alertas
- Criar planos de resposta a incidentes

Exemplo do Mundo Real:

Um atacante inunda um site de e-commerce com requisições durante a Black Friday, tornando-o indisponível para clientes legítimos e causando perda de receita.

E – Elevação de Privilégios (Elevation of Privilege)

Definição:

Obter permissões de nível superior às autorizadas.

Exemplos:

- Explorar buffer overflows para obter acesso de administrador
- Injeção SQL para contornar a autenticação

- Escalação de privilégios por meio de configurações incorretas
- Explorar configurações vulneráveis de sudo
- Ataques de escape de container

Estratégias de Mitigação:

- Implementar o princípio do mínimo privilégio
- Patches de segurança regulares
- Usar controle de acesso baseado em funções (RBAC)
- Validação de entrada
- Práticas de codificação segura
- Avaliações de segurança regulares
- Implementar limites de permissão adequados

Exemplo do Mundo Real:

Um usuário comum explora uma vulnerabilidade em uma aplicação web para obter privilégios de administrador e acessar dados sensíveis de clientes.

Tabela de Mapeamento STRIDE

Componente	Falsificação o	Adulteração o	Repúdio	Divulgação o	DoS	Elevação
Entidade Externa	☐	☐				
Processo	☐	☐	☐	☐	☐	☐
Armazenamento de Dados		☐	☐	☐		
Fluxo de Dados		☐		☐	☐	

Sistema de Avaliação DREAD

DREAD é um modelo quantitativo de avaliação de risco que classifica as ameaças com base em cinco fatores. Cada fator é pontuado de 1 a 10.

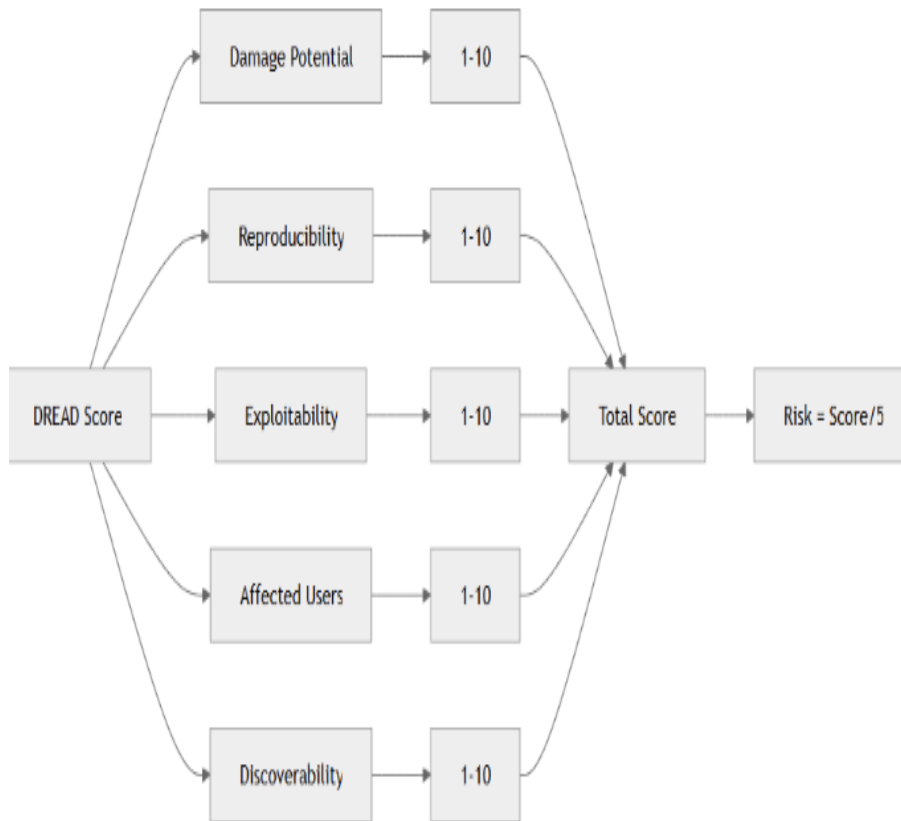


Figura 8 – Fatores do Sistema DREAD

D – Potencial de Dano (Damage Potential)

Pergunta: Quanto dano será causado se a vulnerabilidade for explorada?

Escala de Avaliação:

- 10: Comprometimento total do sistema, perda de dados ou ruína financeira
- 7-9: Violação significativa de dados ou perda importante de funcionalidade
- 4-6: Exposição limitada de dados ou impacto moderado
- 1-3: Impacto mínimo no sistema ou nos dados

Exemplos:

- Injeção SQL expondo todos os registros de clientes: 10
- Ataque XSS em uma única página: 4

R – Reprodutibilidade (Reproducibility)

Pergunta: Quão fácil é reproduzir o ataque?

Escala de Avaliação:

- 10: O ataque funciona sempre, sem condições especiais necessárias

- 7-9: O ataque funciona na maioria das vezes com esforço mínimo
- 4-6: O ataque requer condições ou timing específicos
- 1-3: Muito difícil de reproduzir, requer circunstâncias raras

Exemplos:

- Autenticação ausente em endpoint de API: 10
- Condição de corrida (race condition) que ocorre ocasionalmente: 3

E – Explorabilidade (Exploitability)

Pergunta: Quão fácil é lançar o ataque?

Escala de Avaliação:

- 10: Requer apenas um navegador web, sem ferramentas especiais
- 7-9: Requer ferramentas básicas de hacking (Burp Suite, SQLmap)
- 4-6: Requer ferramentas avançadas e habilidade moderada
- 1-3: Requer ferramentas personalizadas e habilidades de nível especialista

Exemplos:

- Clicar em um link malicioso: 10
- Explorar uma vulnerabilidade de zero-day: 2

A – Usuários Afetados (Affected Users)

Pergunta: Quantos usuários serão afetados?

Escala de Avaliação:

- 10: Todos os usuários afetados
- 7-9: Maioria dos usuários afetados
- 4-6: Número significativo de usuários afetados
- 1-3: Muito poucos usuários afetados

Exemplos:

- Bypass de autenticação afetando todos os usuários: 10
- Vulnerabilidade em recurso de admin raramente usado: 2

D – Descobertabilidade (Discoverability)

Pergunta: Quão fácil é descobrir a vulnerabilidade?

Escala de Avaliação:

- 10: A vulnerabilidade é óbvia, visível no navegador
- 7-9: Pode ser encontrada com ferramentas de varredura automatizadas
- 4-6: Requer alguma investigação e análise
- 1-3: Requer análise de código-fonte ou conhecimento interno

Exemplos:

- Chaves de API expostas em JavaScript: 10
- Falha lógica em processo de negócio complexo: 3

Exemplo de Cálculo DREAD

Vulnerabilidade: Transmissão de senha sem criptografia

Fator	Pontuação	Justificativa
Dano (D)	9	Pode comprometer contas de usuários
Reprodutibilidade (R)	10	Ocorre a cada login

Fator	Pontuação	Justificativa
Explorabilidade (E)	8	Fácil com ferramentas de sniffing de rede
Usuários Afetados (A)	10	Todos os usuários afetados
Descobertabilidade (D)	9	Visível no tráfego de rede

TOTAL	46	NÍVEL DE RISCO	9,2/10	CRÍTICO
-------	----	----------------	--------	---------

Interpretação do Nível de Risco:

- 8,0–10,0: Crítico – Corrigir imediatamente
- 6,0–7,9: Alto – Corrigir em dias
- 4,0–5,9: Médio – Corrigir em semanas
- 2,0–3,9: Baixo – Corrigir quando possível
- 0,0–1,9: Informativo – Considerar correção

Processo PASTA

PASTA (Process for Attack Simulation and Threat Analysis) é uma metodologia de modelagem de ameaças em sete estágios, centrada em risco.

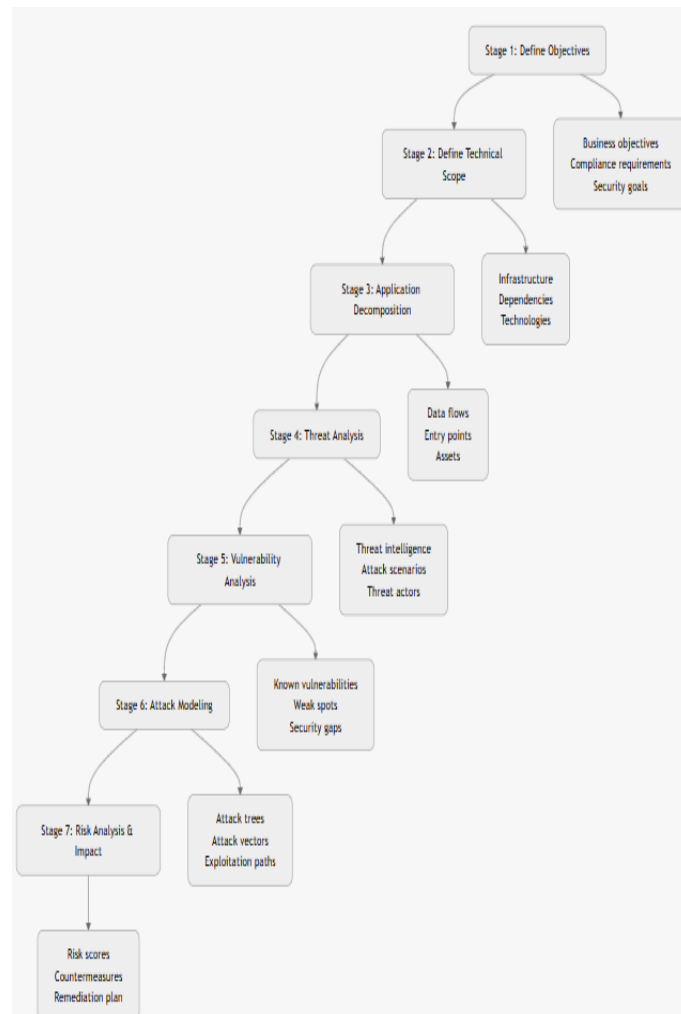


Figura 9 – Os sete estágios do processo PASTA

Estágio 1: Definir Objetivos

Definir os objetivos de negócio e os requisitos de segurança.

Atividades:

- Identificar objetivos de negócio
- Definir requisitos de segurança e conformidade
- Determinar tolerância ao impacto
- Estabelecer critérios de sucesso

Saída: Documento de objetivos de segurança

Estágio 2: Definir Escopo Técnico

Definir o escopo técnico da análise.

Atividades:

- Inventariar hardware e software
- Documentar arquitetura de rede
- Identificar dependências e integrações

- Definir fronteiras

Saída: Documento de escopo técnico

Estágio 3: Decomposição da Aplicação

Decompor a aplicação em seus componentes.

Atividades:

- Criar diagramas de fluxo de dados (DFDs)
- Identificar fronteiras de confiança
- Documentar atores e funções
- Mapear fluxos de dados

Saída: Diagramas de arquitetura detalhados

Estágio 4: Análise de Ameaças

Analisar ameaças potenciais usando fontes de inteligência.

Atividades:

- Revisar feeds de inteligência de ameaças
- Identificar agentes de ameaça relevantes
- Analisar padrões de ataque
- Considerar ameaças específicas do setor

Saída: Lista de cenários de ameaça

Estágio 5: Análise de Vulnerabilidades

Identificar vulnerabilidades existentes e potenciais.

Atividades:

- Revisar vulnerabilidades existentes (CVEs)
- Analisar código em busca de fraquezas
- Revisar configurações
- Conduzir avaliações de segurança

Saída: Relatório de avaliação de vulnerabilidades

Estágio 6: Modelagem de Ataques

Modelar como os ataques podem ser executados.

Atividades:

- Criar árvores de ataque
- Mapear vetores de ataque
- Simular cenários de ataque
- Identificar caminhos de exploração

Saída: Modelos de simulação de ataque

Estágio 7: Análise de Risco e Impacto

Analisar riscos e priorizar a remediação.

Atividades:

- Calcular pontuações de risco
- Priorizar ameaças
- Recomendar contramedidas

- Criar roadmap de remediação

Saída: Plano de gerenciamento de risco

OCTAVE – Avaliação Operacionalmente Crítica de Ameaças, Ativos e Vulnerabilidades

O modelo de ameaças OCTAVE é uma técnica estratégica de avaliação e planejamento de segurança baseada em risco. Foi desenvolvido pela Carnegie Mellon University's Software Engineering Institute (SEI) e é adaptado para o gerenciamento de risco organizacional, em vez de focar exclusivamente em vulnerabilidades técnicas. O OCTAVE envolve três fases distintas:

Fase 1 – Criar perfis de ameaça baseados em ativos:

Determinar quais ativos são mais importantes para a organização — como bancos de dados, propriedade intelectual, informações de clientes e infraestrutura crítica — e estabelecer requisitos de segurança com base nas ameaças identificadas para garantir a proteção dos ativos críticos.

Fase 2 – Identificar vulnerabilidades de infraestrutura:

Revisar a infraestrutura tecnológica da organização para identificar vulnerabilidades que possam ser exploradas e avaliar as práticas e políticas de segurança atuais para encontrar lacunas ou fraquezas.

Fase 3 – Desenvolver estratégia e planos de segurança:

Avaliar os riscos para a organização considerando o impacto e a probabilidade das ameaças e vulnerabilidades identificadas. Formular estratégias para mitigar os riscos identificados, que podem incluir mudanças de política, soluções tecnológicas e práticas organizacionais.

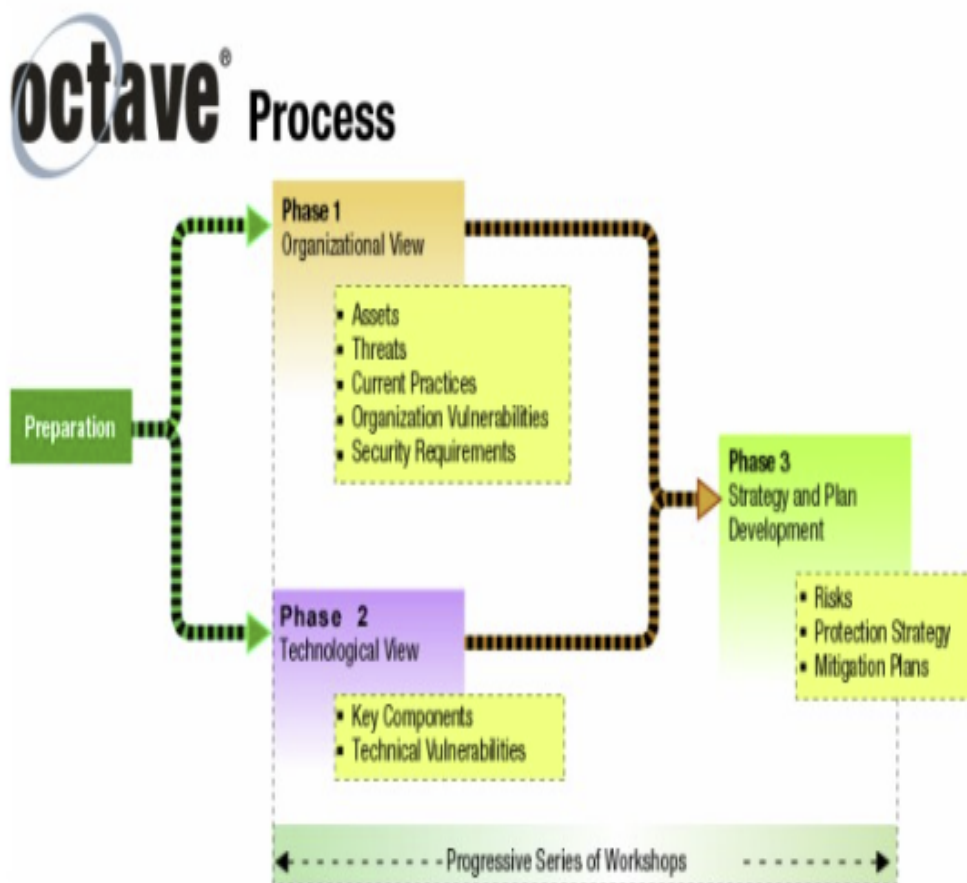


Figura 10 – Fluxo do processo OCTAVE em três fases

Este fluxograma representa a abordagem OCTAVE para avaliação de riscos de segurança da informação, organizada em três fases:

Fase 1: Visão Organizacional

Esta fase foca na avaliação organizacional. A equipe de análise identifica ativos críticos relacionados à informação, determina as medidas de proteção atuais e cria perfis de ameaças baseados em ativos.

- Ativos
- Ameaças
- Práticas Atuais
- Vulnerabilidades Organizacionais
- Requisitos de Segurança

Fase 2: Visão Tecnológica

Esta fase avalia a infraestrutura de informação da organização. A equipe identifica vulnerabilidades de infraestrutura.

- Componentes-chave
- Vulnerabilidades Técnicas

Fase 3: Desenvolvimento de Estratégia e Plano

Nesta fase, a equipe de análise desenvolve estratégias de proteção e planos de mitigação.

- Riscos
- Estratégia de Proteção
- Planos de Mitigação

Árvores de Ataque (Attack Trees)

As árvores de ataque são uma representação visual dos ataques contra um sistema, mostrando o objetivo no topo e os diversos caminhos para alcançá-lo abaixo.

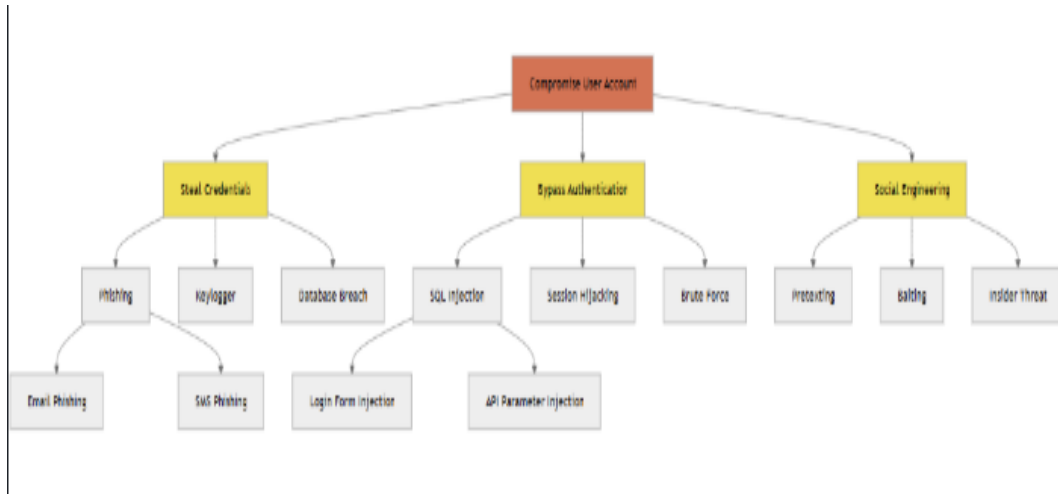


Figura 11 – Estrutura de uma Árvore de Ataque

Componentes das Árvores de Ataque

- Nó Raiz: O objetivo final do atacante
- Nós OR: Diferentes formas de atingir um objetivo (qualquer caminho que funcione)
- Nós AND: Etapas obrigatórias que devem ser todas concluídas
- Nós Folha: Ações de ataque específicas e atômicas

Exemplo de Árvore de Ataque: Violação de Dados em E-commerce

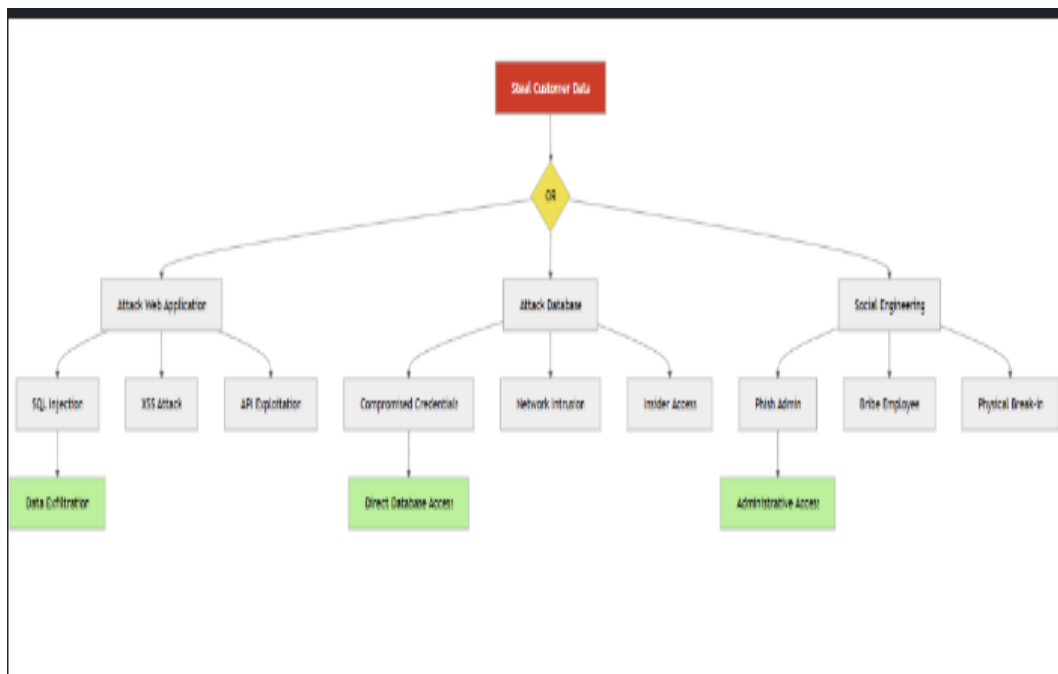


Figura 12 – Árvore de ataque para violação de dados em e-commerce

Usando Árvores de Ataque

Benefícios:

- Representação visual dos cenários de ataque

- Ajuda a identificar múltiplos caminhos de ataque
- Facilita a análise de risco
- Apoia decisões de investimento em segurança
- Comunica ameaças a partes interessadas não técnicas

Passos para Criar uma Árvore de Ataque:

- Identificar o objetivo do atacante (raiz)
- Brainstorm de formas de atingir esse objetivo
- Decompor cada abordagem em sub-objetivos
- Continuar até chegar às ações atômicas
- Atribuir probabilidade e custo a cada caminho
- Priorizar defesas com base na análise

Comparação de Metodologias

A escolha da metodologia correta depende do contexto do projeto, do prazo e dos objetivos.

Metodologia	Melhor Para	Complexidade	Tempo Necessário	Saída
STRIDE	Uso geral, fase de design	Baixa–Média	2–4 horas	Categorias de ameaça
DREAD	Priorização de riscos	Baixa	1–2 horas	Pontuações quantitativas
PASTA	Análise abrangente	Alta	2–3 dias	Avaliação completa de risco
OCTAVE	Avaliações de risco organizacional e governança	Média–Alta	1–2 dias	Perfil de risco focado em negócio
Árvores de Ataque	Comunicação visual, cenários específicos	Média	3–6 horas	Diagramas de caminho de ataque

Quando Usar Cada Metodologia

Use STRIDE quando:

- Iniciar um novo projeto
- Precisar de uma abordagem sistemática
- Trabalhar com equipes de desenvolvimento
- O tempo for limitado mas a cobertura for importante
- Quiser uma metodologia padronizada pela indústria

Use DREAD quando:

- Tiver múltiplas ameaças a priorizar
- Precisar justificar investimentos em segurança
- Comunicar com a gestão
- Quiser pontuações de risco quantificáveis
- Os recursos forem limitados

Use PASTA quando:

- Construir sistemas críticos
- A conformidade exigir análise abrangente
- Tiver tempo e recursos disponíveis
- Executivos precisarem de relatórios detalhados
- Uma abordagem centrada em risco for necessária

Use Árvores de Ataque quando:

- Analisar cenários de ataque específicos
- Comunicar com partes interessadas não técnicas
- Identificar estratégias de defesa otimizadas
- Avaliar investimentos em segurança
- Ensinar conceitos de segurança

Use OCTAVE (especialmente OCTAVE Allegro) quando:

- Alinhar prioridades de segurança com líderes de negócio e executivos
- Realizar avaliações de risco em nível empresarial, departamental ou centradas em informação
- Permitir que equipes de negócio conduzam o processo de risco
- Atender a requisitos de conformidade (ISO 27001, NIST CSF, SOC 2, HIPAA, PCI DSS)

- Operar com equipes de segurança pequenas ou sobrecarregadas

Abordagem Combinada

Muitas organizações combinam metodologias:

- STRIDE para identificar ameaças sistematicamente
- Árvores de Ataque para visualizar caminhos de ataque críticos
- DREAD para priorizar esforços de remediação
- PASTA para revisões abrangentes periódicas
- OCTAVE Allegro para avaliações de risco empresariais e conformidade

Conclusão Principal: Comece com STRIDE para amplitude, use Árvores de Ataque para profundidade nos ativos críticos e DREAD para priorização.

4. O Processo de Modelagem de Ameaças

O processo de modelagem de ameaças é uma metodologia estruturada em seis etapas para identificar, avaliar e mitigar riscos de segurança ao longo do ciclo de vida de um sistema ou aplicação. Cada etapa constrói o entendimento do que você está protegendo, como os atacantes podem interagir com o sistema e quais controles reduzem os riscos de forma mais eficaz.

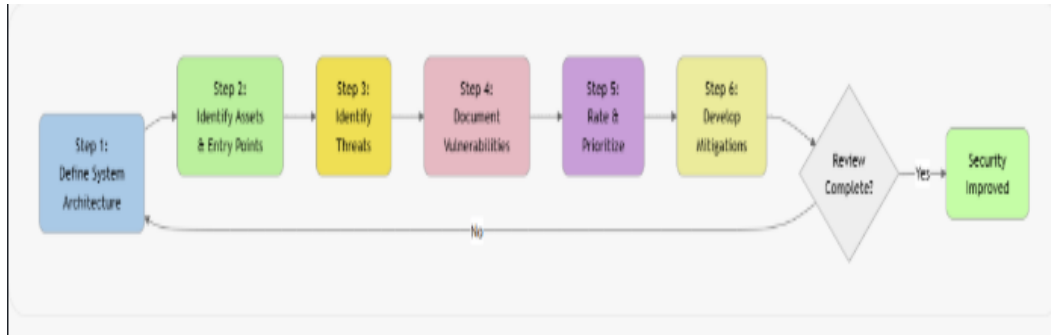


Figura 13 – Visão geral do processo de modelagem de ameaças em 6 etapas

Etapa 1 – Definir Arquitetura e Escopo do Sistema

O processo começa estabelecendo o que precisa ser protegido por meio de uma definição clara da arquitetura e do escopo do sistema. Isso envolve documentar suposições, restrições e requisitos de negócio, além de produzir diagramas de arquitetura — como Diagramas de Fluxo de Dados (DFDs) — que ilustram componentes do sistema, fluxos de dados e fronteiras de confiança. Declarar explicitamente o que está dentro e fora do escopo garante que a análise se concentre nos elementos corretos.

Etapa 2 – Identificar Ativos e Pontos de Entrada

A próxima etapa é identificar e classificar todos os ativos valiosos com base em suas necessidades de confidencialidade, integridade e disponibilidade. Esses ativos incluem dados sensíveis, mecanismos de autenticação, APIs, componentes de infraestrutura e interfaces administrativas. Em paralelo, todos os pontos de entrada — como páginas de login, APIs, endpoints de upload de arquivos e painéis de administração — são catalogados para determinar onde os atacantes podem interagir com o sistema.

Etapa 3 – Identificar Ameaças

Com ativos e pontos de entrada compreendidos, as ameaças são identificadas usando metodologias estruturadas como o STRIDE. Cada fluxo de dados, componente e armazenamento de dados é examinado em busca de riscos potenciais, incluindo falsificação, adulteração, repúdio, divulgação de informações, negação de serviço e elevação de privilégios. Cenários de ameaça e personas de atacantes ajudam a garantir uma compreensão completa e realista de como o sistema pode ser atacado.

Etapa 4 – Documentar Vulnerabilidades

Esta etapa foca em identificar fraquezas que podem possibilitar as ameaças identificadas. As vulnerabilidades são descobertas por meio de revisões de código, auditorias de configuração, análise de dependências e ferramentas de varredura automatizadas. Cada vulnerabilidade é documentada e mapeada para as ameaças correspondentes, ativos e áreas do sistema afetadas, a fim de manter rastreabilidade e clareza.

Etapa 5 – Avaliar e Priorizar Riscos

Todas as ameaças e vulnerabilidades são então avaliadas e priorizadas usando métodos de pontuação de risco como DREAD ou CVSS. Esta análise considera tanto o impacto quanto a probabilidade, resultando em uma lista classificada de riscos que orienta os esforços de remediação. A saída final inclui um backlog de remediação, uma matriz de risco e um sumário executivo destacando os riscos mais críticos.

Etapas 6 – Desenvolver e Implementar Estratégias de Mitigação

A etapa final consiste em definir e aplicar estratégias de mitigação para reduzir ou eliminar os riscos priorizados. Essas estratégias podem incluir controles preventivos (ex.: validação de entrada, fortalecimento da autenticação), controles de detecção (registro e monitoramento), ações corretivas (aplicação de patches, limitação de taxa) e controles compensatórios quando as soluções ideais não forem viáveis. Cada mitigação é verificada por meio de testes para garantir que aborda efetivamente os riscos associados.

Processo Iterativo

A modelagem de ameaças não é uma atividade única:

Quando Atualizar os Modelos de Ameaça:

- Novas funcionalidades ou recursos
- Mudanças de arquitetura
- Nova inteligência de ameaças
- Após incidentes de segurança
- Mudanças nos requisitos de conformidade
- Anualmente, no mínimo

Conclusão Principal: A modelagem de ameaças é um processo vivo que deve evoluir junto com o seu sistema e o cenário de ameaças.